

Master's Thesis Defence

An OWL-Based Ontology for NIS2 Article 21 Compliance

Supervisor: Prof. Enrico Francesconi

Candidate: Abdul Kader

OWL 2 DL | SHACL | SPARQL

Research problem and objective

Motivation for a formal compliance model

- NIS2 Article 21 requires technical, operational, and organizational measures.
- Assessment is often manual and difficult to reproduce consistently.
- The thesis turns Article 21 into a machine-readable model.

What the thesis contributes

- OWL 2 DL ontology covering Article 21(2) measure categories.
- SHACL constraints for missing or incomplete evidence.
- A compact web app for inspection, querying, and visualization.

Research objective

Transform legal obligations into a structured compliance artifact that can be checked, queried, and explained.

Article 21 measure map

The thematic areas that structure the ontology model

Ten thematic areas in NIS2 Article 21(2)

Redrawn as text for presentation readability instead of scaling a tall infographic.

1	Risk analysis and information-system security policies	2	Incident handling
3	Business continuity and crisis management	4	Supply-chain security
5	Security in network and information systems acquisition, development, and maintenance	6	Policies and procedures to assess cybersecurity risk-management effectiveness
7	Basic cyber hygiene practices and cybersecurity training	8	Cryptography and encryption policies and procedures
9	Human resources security, access-control policies, and asset management	10	Multi-factor authentication and secure communications

How the map is used

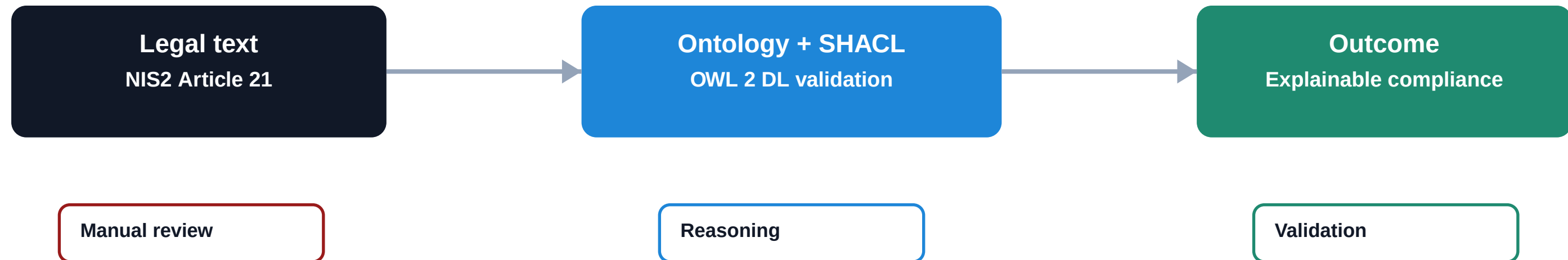
- Article 21 measure categories become ontology classes.
- The ten legal points are refined into twelve operational classes.
- The same classes drive reasoning, SHACL validation, and SPARQL checks.

Methodological approach

From legal text to computable compliance

Problem -> model -> outcome

A compact thesis workflow from legal interpretation to machine-checkable compliance output.



Simple thesis workflow: legal text -> ontology -> validation -> outcome

- Design-science: build the artifact and evaluate it against representative cases.
- OWL 2 DL supports classification and reasoning.
- SHACL and SPARQL support validation and querying.

Modeling decision

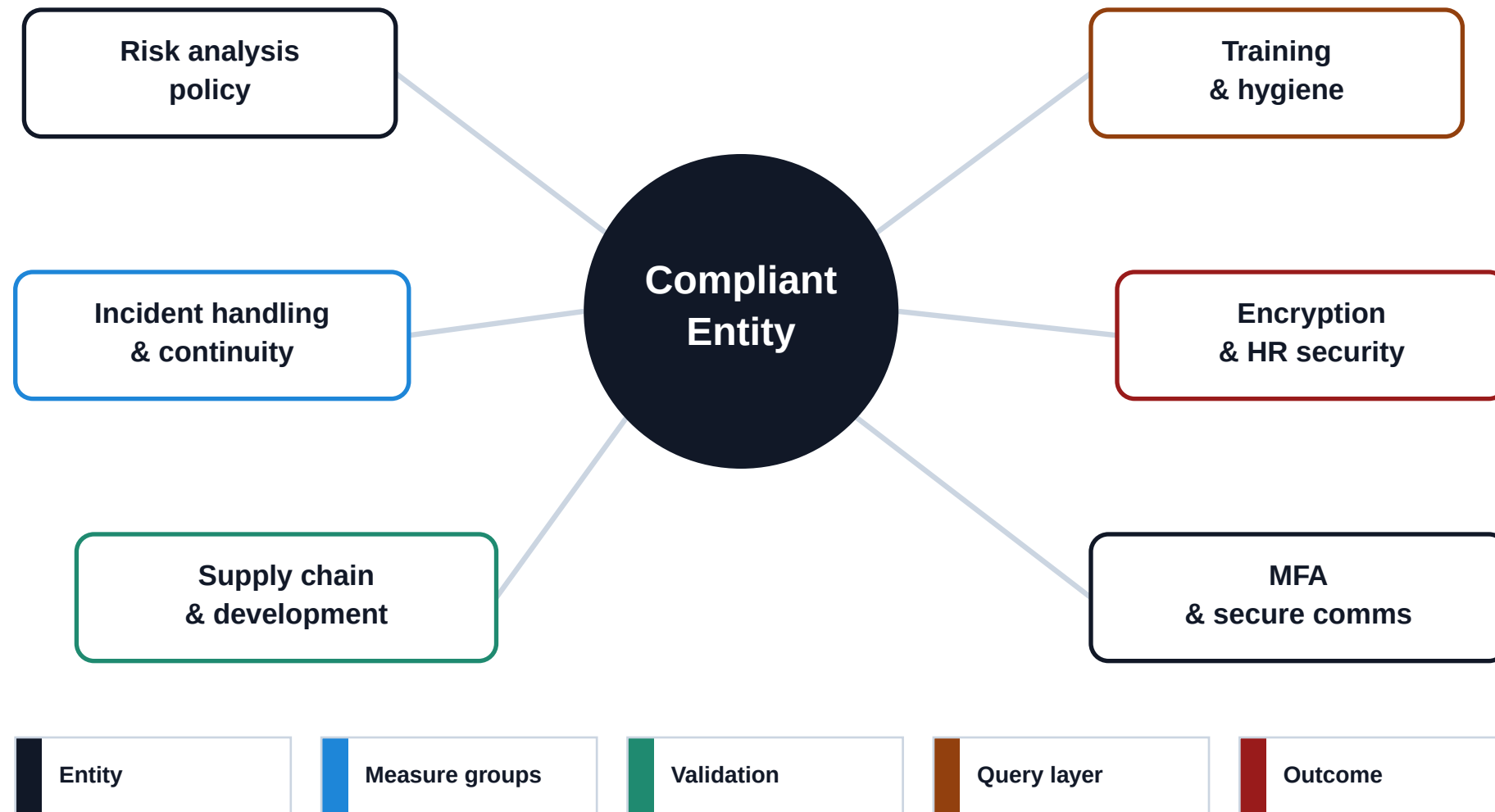
The thesis models the ten legal points as twelve operational classes, separating points (g) and (j) where the wording combines distinct concerns.

Ontology model

The structure that makes compliance computable

Ontology structure

A central compliant entity supported by Article 21 measure groups.



Ontology structure with a central compliance entity and the required measure groups

Key concepts

- Entity
- RiskManagementMeasure
- Article 21 measure classes

Why it matters

- Legal references remain traceable.
- Reasoning can explain compliance results.

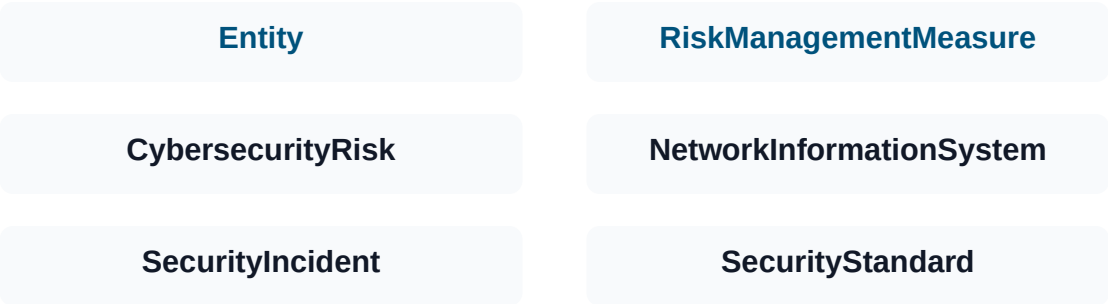
Dissertation figures: ontology implementation

Selected implementation figures from Chapter 6

Figure 6.1: OWL class hierarchy

Readable reconstruction of the Protégé hierarchy used in the thesis implementation.

Top-level ontology classes



RiskManagementMeasure subclasses

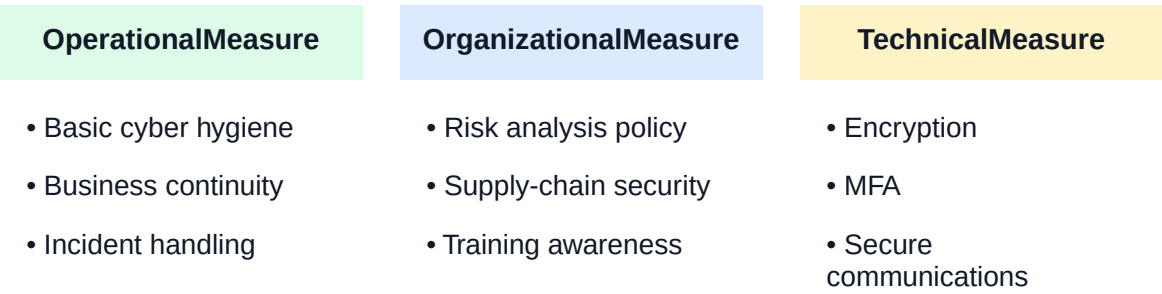
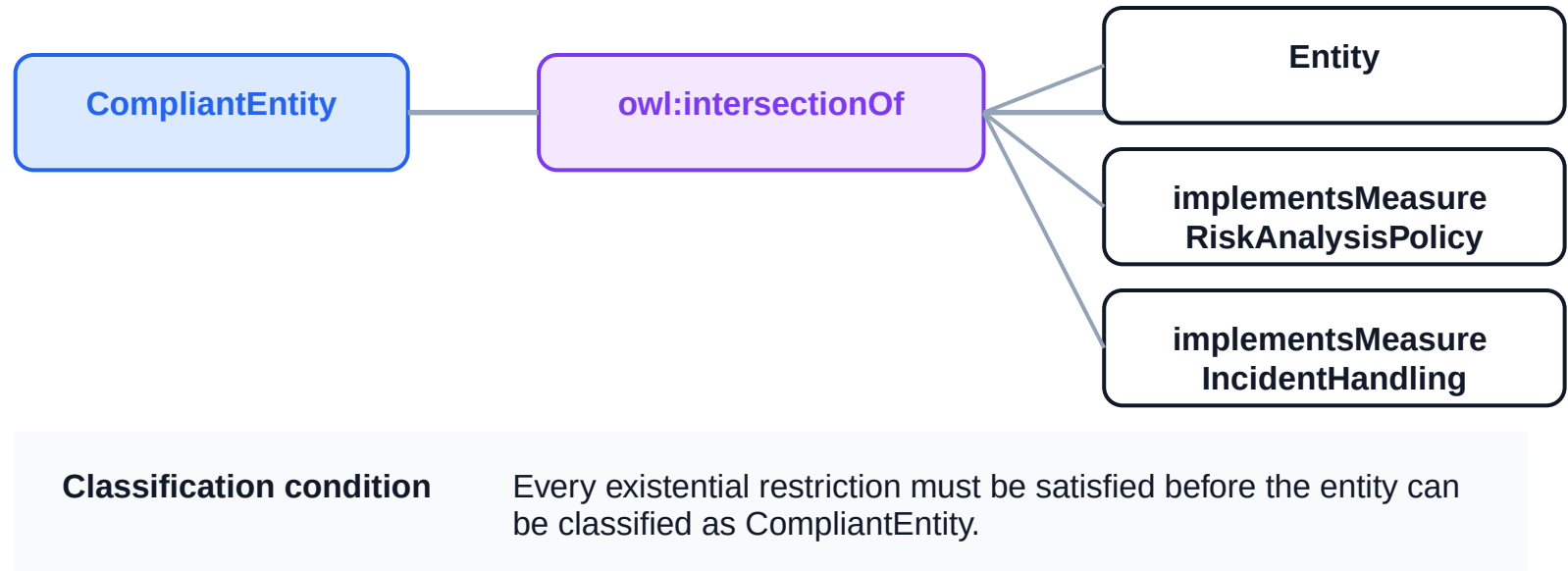


Figure 6.1: Protégé class hierarchy for the NIS2 Article 21 ontology

Figure 6.4: CompliantEntity axiom

OWL equivalent-class structure represented as an intersection of entity type and required measures.



Interpretation

The ontology is implemented in OWL, inspected in Protégé, and centered on a compliance class covering the Article 21 measure categories.

Example: Article 21 rule implemented and checked

Article 21(2)(c): business continuity and crisis management

1. Legal rule

Article 21(2)(c) requires business continuity, backup management, disaster recovery and crisis management.

2. Ontology implementation

The legal rule is modeled as an OWL class:

:BusinessContinuityManagement

with article reference:

"Article 21(2)(c)"

The entity is checked through :implementsMeasure links.

3. SPARQL compliance check

```
PREFIX : <https://w3id.org/nis2/article21#>

ASK {
  :MedCenterHospital :implementsMeasure ?m .
  ?m a :BusinessContinuityManagement .
}

# Result: false
```

Compliance interpretation

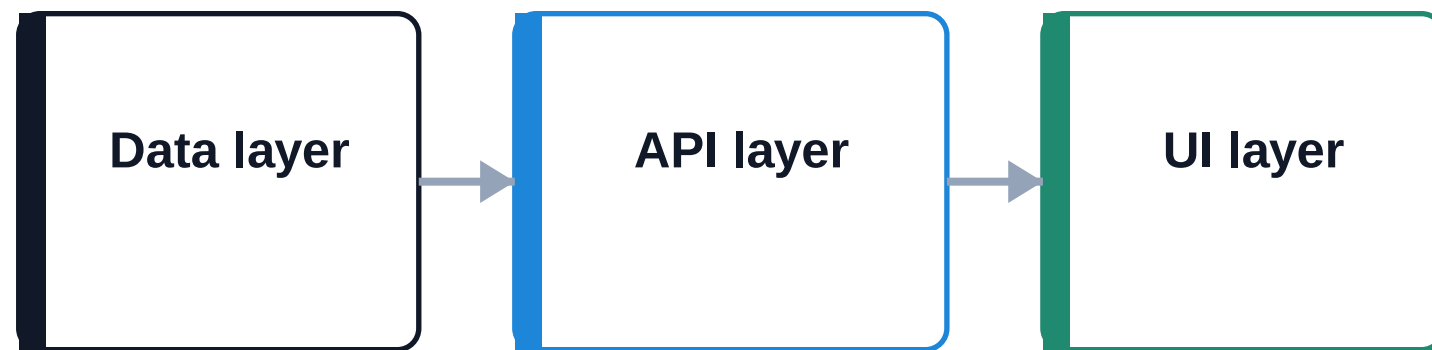
For MedCenterHospital, the ASK query returns false: no implemented measure is typed as BusinessContinuityManagement. Therefore, the prototype reports Article 21(2)(c) as a missing requirement.

Web application prototype

How the implementation makes the ontology usable

System architecture

Three layers: ontology data, backend services, and browser UI.



Prototype architecture: ontology data, backend API, and browser interface

Technology used

- Node.js and Express backend
- RDF/OWL parsing with rdf-parse and N3
- Browser interface with HTML, CSS, and JavaScript
- Ontology files served as TTL/OWL data

Role in solving the problem

The web application turns the formal ontology into an inspectable tool: users can browse the model, run checks, and see which Article 21 obligations are satisfied or missing.

Validation and results

Prototype-level evaluation findings

Partial healthcare case

Representative validation result: implemented measures are matched against Article 21 categories.

Art.	Requirement category	Evidence state	Verdict
(a)	Risk analysis policies	Implemented	COMPLIANT
(b)	Incident handling	Implemented	COMPLIANT
(c)	Business continuity	No measure asserted	VIOLATION
(d)	Supply-chain security	No measure asserted	VIOLATION
(e)	Acquisition and development	No measure asserted	VIOLATION
(f)	Effectiveness assessment	No measure asserted	VIOLATION
(g)	Cyber hygiene and training	Training awareness	COMPLIANT
(h)	Cryptography and encryption	Encryption implemented	COMPLIANT
(i)	HR, access, and assets	No measure asserted	VIOLATION
(j)	MFA and secure comms	MFA only; secure comms missing	PARTIAL

Worked example from the thesis showing the partial healthcare case and verdicts

Observed outcome

12 / 12

Full coverage: compliant classification.

6 / 12

Partial coverage: gaps are exposed.

Interpretation

- The result measures modeled coverage, not legal certification.
- Missing requirement categories are identified explicitly.

Comparison and limitations

Scope of contribution and stated boundaries

Comparison with existing approaches

The thesis combines semantics, reasoning, SPARQL, and SHACL in one demonstrator.

Approach	Formal semantics	Auto reasoning	SPARQL	SHACL	Open source
This thesis	Yes	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No
Manual checklist	No	No	No	No	Yes

Comparison from the thesis: OWL + SHACL + SPARQL in one demonstrator

Strength

- Formal semantics through OWL 2 DL
- Constraint validation through SHACL

Limitations

- Reasoning is demonstrated within a bounded prototype setting.
- Production-grade evidence governance remains future work.

Dissertation figures: prototype outputs

Reasoning and real-time compliance assessment

Structural reasoning result

Classification, missing operational classes, and inferred standards.

PASS

ExampleCompliantEntity

12 / 12 operational classes -> CompliantEntity

GAP

ExampleNonCompliantEntity

5 / 12 classes implemented -> gaps reported

Missing operational classes

Business continuity

Secure development

HR security

Secure communications

Supply-chain security

Effectiveness assessment

MFA

Standards inferred for the complete entity

ISO27001

ISO27002

NIST

ENISA

CIS Controls

Real-time compliance check

Submitted class coverage without modifying the ontology.

COMPLIANT

Score

100%

Coverage

12 / 12

Class

OWL

Selected operational classes

Risk analysis

Business continuity

Secure development

Cyber hygiene

HR security

MFA

Incident handling

Supply chain

Effectiveness

Training

Encryption

Secure comms

Derived standards

ISO27001

ISO27002

NIST

ENISA

CIS

Dissertation figures: SPARQL query layer

Competency-question execution over the ontology graph

SPARQL competency query

CQ2: standards associated with the complete example entity.

```
PREFIX nis2: <https://w3id.org/nis2/article21#>

SELECT ?entity ?standard
WHERE {
  ?entity a nis2:CompliantEntity .
  ?entity nis2:implementsMeasure ?measure .
  ?measure nis2:basedOnStandard ?standard .
}
```

Query results

entity	standard
ExampleCompliantEntity	ISO27001
ExampleCompliantEntity	ISO27002

What this demonstrates

- The ontology can be inspected through query patterns.
- Standards linked to a compliant entity can be retrieved from the graph.

This slide completes the sequence: ontology representation, validation, reasoning, and information retrieval.

Approach, alternatives, and limits

Likely defence questions answered directly

Why OWL?

- Formal semantics for Article 21 concepts.
- Class hierarchy and reusable vocabulary.
- Reasoning can infer CompliantEntity.

Alternatives considered

- Spreadsheets are simple but cannot reason.
- Databases store structure, not legal meaning.
- Rule engines are weaker as shared vocabulary.

Type of data

- RDF triples, OWL classes, and properties.
- SHACL shapes and SPARQL query results.
- Example claims, not verified legal evidence.

Website UI

- Graph visualization of ontology relations.
- Validation, reasoning, SHACL, SPARQL panels.
- Real-time entity compliance checker.

Challenges

- Translating legal text into precise classes.
- Handling OWL open-world semantics.
- Reporting missing evidence without overclaiming.

Limits and next step

- Research prototype, not official certification.
- Use complete OWL, SHACL, and SPARQL engines.
- Add evidence, provenance, and real cases.

Conclusion

Final synthesis of the research contribution

Main takeaway

NIS2 Article 21 compliance can be represented as a formal ontology, validated with SHACL, queried with SPARQL, and explained through a compact prototype.

Core claims

- Manual verification becomes more consistent through formal representation.
- A traceable ontology bridges legal text and compliance evidence.

Thank you

Future work

Research extensions and validation requirements

Next steps

- Integrate the prototype with a standards-complete reasoner.
- Add evidence, provenance, and review metadata.
- Evaluate the system with realistic organizational data.

Comparison with existing approaches

The thesis combines semantics, reasoning, SPARQL, and SHACL in one demonstrator.

Approach	Formal semantics	Auto reasoning	SPARQL	SHACL	Open source
This thesis	Yes	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No
Manual checklist	No	No	No	No	Yes

Comparison from the thesis: OWL + SHACL + SPARQL in one demonstrator

A concise reminder that the thesis combines semantics, validation, and querying.

Closing point This work is a formal compliance demonstrator, not a production deployment.